



Overview dos Certificados — antes de começar

Preparado para **Eduardo de Souza Marques** · 2026-09-22 · para ter a NOÇÃO geral antes de mergulhar no curso (Prof. Messer etc.)

Como usar este material: não é pra decorar — é pra tu **reconhecer o mapa** antes de entrar no curso. Lê cada overview, e quando o professor falar "CIA triad", "CVSS", "shared responsibility", teu cérebro já tem onde encaixar. Isso acelera MUITO o aprendizado. Ordem sugerida no fim.

Cert	Papel	Quando	Prova
Security+	A chave de entrada (filtro de RH)	AGORA (1º)	~90 Q · 90 min · \$404
Linux (Essentials→RHCSA)	Base técnica de toda vaga	paralelo	Essentials ~40 Q; RHCSA prático
Cloud (CLF-C02/AZ-900/SC-900)	Nuvem — requisito onipresente	junto do Sec+	~65 Q · 90 min · ~\$100
CySA+	Análise/SOC — degrau 2	+6-12 meses	~85 Q · 165 min · \$404
SecAI+	★ Segurança de IA — teu diferencial raro	diferencial	nova (CompTIA)

1 · CompTIA Security+ (SY0-701)

CompTIA

~US\$404

90 Q · 90 min

passa 750/900

vale 3 anos

MCQ + PBQ (prática)

A certificação de entrada mais reconhecida. Prova conhecimento amplo de segurança. É o que abre SOC e Vulnerability Management júnior. O curso do Prof. Messer (grátis no YouTube, ~12h de vídeo) cobre 100% dela.

Os 5 domínios (o que cai + peso)

#	Domínio	Peso
1	Conceitos gerais de segurança	12%
2	Ameaças, vulnerabilidades e mitigações	22%
3	Arquitetura de segurança	18%
4	Operações de segurança	28%
5	Gestão do programa de segurança (GRC)	20%

🔴 Overview resumido — os conceitos-mãe:

- **CIA:** Confidencialidade, Integridade, Disponibilidade — todo controle serve a um desses. + **AAA** (Autenticação, Autorização, Auditoria).
- **Tipos de controle:** técnico / gerencial / operacional / físico — e preventivo / detectivo / corretivo / dissuasivo / compensatório.
- **Princípios:** Zero Trust ("nunca confie, sempre verifique"), menor privilégio, defesa em profundidade.
- **Criptografia:** simétrica (AES, mesma chave) vs assimétrica (RSA, par de chaves) · hash (SHA, mão única, integridade) · PKI/certificados · assinatura digital.
- **Ameaças:** tipos de malware, engenharia social (phishing/whaling/BEC), ataques (on-path, injeção SQL, DDoS), atores (nation-state, insider...).
- **Identidade (IAM):** MFA (algo que sabe/tem/é), SSO, federação, provisionamento.
- **Rede:** firewall, IDS/IPS, VPN, segmentação, protocolos seguros (SSH, TLS/HTTPS).
- **Operações:** SIEM, análise de log, resposta a incidente (fases NIST), forense (ordem de volatilidade), gestão de vulnerabilidade (CVE, CVSS 0-10).
- **GRC:** risco (RTO=tempo, RPO=dado; aceitar/evitar/transferir/mitigar), frameworks (NIST/ISO), leis (GDPR/HIPAA), BCP/DR, políticas.

🎯 **Como estudar (teu caso, ~40-50h):** assiste a série do **Prof. Messer SY0-701** (YouTube, grátis) → faz as **anotações** → **practice exams** do Messer/Jason Dion, refaz até bater **>85%** consistente → treina as siglas no teu **Treinador** (app). As PBQs (questões práticas) pedem que tu **FAÇA** algo (configurar firewall, ordenar passos) — pratica isso, não só decore.

Teu encaixe: teu fundo investigativo (PMMG) brilha no domínio 4 (operações/incidente) e 2 (ameaças). O domínio 5 (GRC) conversa com tua veia metódica. É a base dos DOIS ramos que tu compara (SOC e GRC/AI Gov).

2 · Linux — Essentials → RHCSA

LPI Linux Essentials ~US\$120

~40 Q · 60 min

→ RHCSA (Red Hat EX200) ~US\$500

RHCSA = 100% prático

Linux aparece em QUASE toda vaga de SOC/infra (servidor, log, scripting). Começa no **Essentials** (teórico, entrada) e sobe pro **RHCSA** (prático, forte no currículo).

Overview resumido — o que dominar:

- **Shell (bash)** e navegação: pwd (onde estou), ls (lista), cd (muda pasta).
- **Arquivos:** cp copia, mv move/renomeia, rm apaga (rm -r recursivo), cat/less lê, find acha, grep busca texto.
- **Permissões:** chmod / chown; rwx (ler/escrever/executar); octal (4+2+1 = 7 = rwx). Ex: chmod 755.
- **Usuários:** /etc/passwd, sudo (roda como root pontual), grupos.
- **Processos:** ps/top (ver), kill (matar por PID).
- **Pacotes:** apt (Debian/Ubuntu) / dnf/yum (Red Hat).
- **Pipes & redirecionamento:** | (encadeia), > (grava), >> (anexa).
- **Hierarquia:** / raiz, /etc configs, /home usuários, /var logs, ~ tua home.
- **Editor:** noções de vi/vim ou nano.

 **Como estudar:** Linux Essentials de graça no **Cisco NetAcad (NDG Linux Unhatched/Essentials)** ou **OverTheWire: Bandit** (joguinho de terminal). Pro RHCSA: precisa de uma **VM Linux** pra praticar de verdade (systemd, LVM, SELinux, firewallld, podman) — é prova de mão na massa, não decoreba.

Teu encaixe: aqui tu ganha autonomia — quem sabe Linux não depende de ninguém pra investigar um servidor. Treina na trilha  do app.

3 · Cloud Fundamentos — AWS CLF-C02 · Azure AZ-900 · MS SC-900

~US\$100 cada

~65 Q · 90 min

nível fundamentos (entrada)

Nuvem pinga em quase todo anúncio. As três são de FUNDAMENTOS (fáceis, baratas). Escolhe 1-2. **SC-900** é a mais alinhada ao teu norte (junta segurança + identidade + nuvem Microsoft).

Cert	Foco	Domínios principais
AWS CLF-C02	Nuvem AWS (a maior do mercado)	Conceitos de nuvem (24%) · Segurança & compliance (30%) · Tecnologia & serviços (34%) · Preço/billing (12%)
Azure AZ-900	Nuvem Microsoft Azure	Conceitos de nuvem · Serviços Azure · Gestão & governança
MS SC-900 ★	Segurança + Compliance + Identidade Microsoft	Conceitos de SCI · Entra ID (identidade) · Soluções de segurança (Defender/Sentinel) · Compliance (Purview)

🗨 Overview resumido — conceitos que se repetem em TODAS:

- **Modelos de serviço:** IaaS (só a infra) · PaaS (plataforma pronta) · SaaS (app pronto, ex Gmail).
- **Responsabilidade compartilhada:** o provedor protege A nuvem (datacenter/hardware); tu proteges NA nuvem (teus dados, acessos, configs). Config errada = tua culpa.
- **Região vs Zona de Disponibilidade (AZ):** Região = área geográfica; AZ = datacenter isolado dentro dela. Espalhar entre AZs = alta disponibilidade.
- **IAM:** quem acessa o quê (menor privilégio na nuvem).
- **Serviços núcleo (AWS):** EC2 (máquina), S3 (storage de objeto), RDS (banco), VPC (rede), Lambda (serverless).
- **Preço:** pay-as-you-go, elasticidade (sobe/desce com a demanda), on-demand vs reserved.
- **Criptografia:** em repouso (dado no disco) vs em trânsito (na rede, TLS).

🎯 **Como estudar (grátis):** Microsoft Learn tem trilha gratuita completa pro AZ-900 e SC-900. AWS Skill Builder tem o curso oficial do CLF-C02 grátis. São as certs mais fáceis da lista — dá pra tirar rápido.

Teu encaixe: SC-900 é ponte perfeita pro teu nicho (segurança de IA roda em nuvem). Treina na trilha 🎧 do app.

4 · CompTIA CySA+ (CS0-003)

CompTIA

~US\$404

~85 Q · 165 min

MCQ + PBQ

degrau 2 (depois do Security+)

A cert de **análise / SOC**. Mais hands-on que o Security+ — foca em DETECTAR e RESPONDER. É o que te tira de júnior. Vagas aceitam "estudando a CySA+".

Domínio	Peso
Operações de segurança	33%
Gestão de vulnerabilidade	30%
Resposta e gestão de incidente	20%
Relatório e comunicação	17%

 **Overview resumido:** análise comportamental · SIEM e correlação de log · threat intelligence e threat hunting · **MITRE ATT&CK** · scan de vulnerabilidade (Nessus/Qualys) e priorização por CVSS · ciclo de resposta a incidente · noções de análise de malware · escrever relatório pra liderança.

 **Como estudar:** só DEPOIS do Security+. Jason Dion / Prof. Messer + laboratório prático (TryHackMe trilha SOC, Blue Team Labs). Aqui teu faro investigativo do PMMG vira ouro.

5 · CompTIA SecAI+ (Segurança + IA) ★ teu diferencial

CompTIA

~US\$400

nova (2025+)

nicho raro

Cert NOVA que junta **Inteligência Artificial + Segurança**. É exatamente o "especialista raro em segurança de IA" que tu quer ser — e é onde vi **salário alto + patrocínio de visto** (vaga Tymon). Casa com teu MS-CS e o EB-2. Por ser nova, tem menos material ainda — objetivos podem evoluir.

📌 Overview resumido — o que essa área cobre:

- **Fundamentos de IA/ML:** como modelos aprendem, LLMs, dados de treino.
- **Ameaças À IA:** adversarial ML (enganar o modelo), **prompt injection**, envenenamento de dados (data poisoning), roubo/inversão de modelo.
- **Proteger sistemas de IA:** segurança do pipeline de ML, das APIs, dos dados.
- **Governança de IA:** IA responsável, risco de modelo, conformidade (NIST AI RMF, ISO 42001, EU AI Act).
- **Usar IA na segurança:** detecção assistida por IA, automação de análise.

🎯 **Como se preparar (mesmo antes da cert): OWASP Top 10 for LLM** (as 10 falhas de apps de IA), **NIST AI RMF** (framework de risco de IA), **MITRE ATLAS** (o "ATT&CK" das ameaças a IA). Esse conhecimento já te posiciona como raro.

Teu encaixe: é o TOPO do teu funil. MS-CS (técnico) + SecAI+/governança de IA + faro investigativo = combinação que quase não existe no mercado.

6 · GRC & AI Governance ★ (teu provável ramo primário)

ramo de carreira remoto-friendly patrocina visto nicho de IA em explosão

GRC = Governance, Risk & Compliance: quem faz as REGRAS, avalia RISCO e AUDITA se a empresa cumpre os frameworks/leis. **AI Governance** é o sub-ramo novo e quente: governar sistemas de IA (risco de modelo, IA responsável, conformidade com EU AI Act / NIST AI RMF / ISO 42001). Menos código, mais política + julgamento + investigação de controle.

Por que provavelmente é o TEU caminho principal: (1) **acessível sem cidadania** — é privado, remoto e patrocina visto (≠ Intelligence, que é muro de clearance); (2) **AI Governance é raro e explodindo** — casa exato com teu MS-CS + SecAI+ + a meta de "especialista raro em IA"; (3) teu fundo do PMMG (investigação) vira "sei auditar se o controle REALMENTE funciona". Vi vagas GRC remotas a US\$50-62/h e a de IA+sponsor (Tymon) a US\$70-75/h.

- 📌 **Overview resumido — o que dominar:**
- **Frameworks:** NIST CSF (Identificar/Proteger/Detectar/Responder/Recuperar) · NIST 800-53 / RMF · **ISO/IEC 27001** (gestão de segurança, SGSI) e 27701 (privacidade) · CIS Controls · COBIT · SOC 2.
 - **Leis/compliance:** GDPR (UE) · CCPA (Califórnia) · HIPAA (saúde US) · GLBA (financeiro US) · LGPD (Brasil) · **EU AI Act** · NIS2.
 - **Risco:** avaliação de risco, apetite de risco, aceitar/evitar/transferir/mitigar, RTO/RPO, matriz de risco.
 - **TPRM:** risco de terceiros/fornecedores (um vazamento deles vira teu problema).
 - **Auditoria:** desenho vs eficácia de controle, evidência, SoA (Statement of Applicability), gap analysis.
 - **Ferramentas:** ServiceNow, RSA Archer, OneTrust, Prevalent, ProcessUnity.

- 🇪🇺 **AI Governance — o que a IA acrescenta (teu diferencial):**
- **EU AI Act:** classifica IA por nível de risco (inaceitável / alto / limitado / mínimo) e impõe obrigações. Primeira grande lei de IA do mundo — empresas correndo pra se adequar.
 - **NIST AI RMF:** framework de risco de IA em 4 funções — **Govern, Map, Measure, Manage**.
 - **ISO/IEC 42001:** a norma de Sistema de Gestão de IA (AIMS) — o "27001 da IA".
 - **Conceitos:** IA responsável, viés/fairness, transparência/explicabilidade, risco de modelo, **OWASP Top 10 for LLM** (falhas de apps de IA).

Certificações do ramo (ordem)

Cert	Emissor	Para quê
CGRC	ISC2	Entrada em governança/risco/compliance (base RMF)
ISO 27001 Lead Implementer / Auditor	PECB / BSI	Implantar/auditar a norma internacional. "Passaporte" B2B.
IAPP AIGP ★	IAPP	AI Governance Professional — a principal cert de governança de IA. Teu diferencial.
ISO 42001 Lead	PECB	Gestão de IA (o "27001 da IA"). Novíssima, rara.
CISA / CRISC / CDPSE	ISACA	Auditoria / risco / privacidade (exigem anos de experiência — destino).

🎯 **Como estudar (grátis pra começar):** lê o **NIST AI RMF** e o resumo do **EU AI Act** (documentos públicos), o **OWASP Top 10 for LLM**, e a estrutura da **ISO 27001**. Isso já te dá vocabulário de AI Governance antes de qualquer cert paga. A base (NIST/ISO/risco) tu já treina no domínio 5 do Security+.

Ponto de convergência (teu unicórnio): "Especialista em Segurança & Governança de IA que também lê o cenário de ameaças" = MS-CS + SecAI+/AIGP + faro investigativo do PMMG. Tronco comum com o ramo SOC = Security+ → frameworks → CySA+; depois afunila pra AI Governance.

Ordem sugerida + fecho

Ordem de ataque:

1. **Security+** — a base e o filtro de RH. Faz primeiro, com o Messer. (~40-50h)
2. **Cloud fundamentos** (SC-900 ou AZ-900) + **Linux Essentials** — fáceis, em paralelo, grátis pra estudar.
3. **PCEP (Python)** — pré-matrícula do MS-CS.
4. Depois de empregado/experiência: **CySA+** (SOC) e **SecAI+** (teu diferencial).
5. Longo prazo: RHCSA, AWS Security, e as sênior (CISSP/CISA).

Regra de ouro: não tenta tudo de uma vez. Security+ na mão já te faz empregável (\$35-48/h nas vagas). O resto vem em camadas. Este PDF é o mapa — o Treinador (app) é onde tu pratica, e o Guia é onde tu acompanha o progresso.

Gerado pelo teu assistente de carreira · fontes: objetivos oficiais CompTIA/LPI/AWS/Microsoft + vagas reais analisadas · 2026-09-22. Valores de prova podem variar por região/data — confirma no site oficial antes de pagar.